

Animated Cursor Vulnerability - Proof of Concept - I

Module 16

Duration: 26:35

Video: <https://www.youtube.com/watch?v=I82Pgkv7Awc>

Course Coordinator - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Subject Expert - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Auto-generated YouTube transcript for personal study. Spoken wording belongs to the original lecture. Follow the video link above; this file is not an official CEC/SWAYAM publication.

in the previous lecture we have discussed about CV and scan CV as you know is common vulnerability and exposure now as I told in the previous class that we are going to explore a real time vulnerability in Windows and that vulnerability is called animated cursor vulnerability now what is this animated cursor vulnerability as you might have seen there are a number of cursors which are available in in window like we have a eye cursor when we are in a notepad we see this kind of a cursor and then we can have a r Glass cursor which is animated which actually flows a sand from one part of a our glass into the another part and many a time you might have seen another cursor which is somebody's riding a horse and that kind of a cursor the horse riding cursor so now as you can see the differentiation

between these cursors these are all animated and their size is different that means this animated cursor is like horse animated cursor it has more size than the r Glass and which has more size than the I cursor now in order to accommodate this Windows implemented the functionality of loading a cursor into a dll file which is called user32.dll now this is a dynamic link Library which is available and this functionality is available in that particular file now if you go to the Web Internet and search for animated cursor vulnerability there's a precursor which is available on the web and this precursor says this vulnerability can be exploited by a malicious web page and it results in remote code execution now there are two things which

we need to learn here one is what I mean by malicious web page and second is remote code execution now when I say malicious web page see whenever a security is implemented in an organization the security is implemented mostly at a peripheries that means whatever traffic is entering into my organization this traffic is getting filtered out by a firewall on the periphery and this kind of a firewall is called Network firewall that means whatever traffic is coming from the outside world into my organization this traffic is going to get filtered at Network firewall level but what happens if somebody from the inside of a network goes to a malicious website I don't have any control over that because most of the organization are allowing HTTP and https traffic to flow

out of their organization so that the people can access web pages now the trouble which is going to come here if a user from my network goes to a particular website and that website itself hosts a malicious code then this particular guy may get affected by that malicious code and this kind of an attack is called client side attack that means today we are going to witness two things in unison one is client side attack and other is this client side attack is going to exploit a vulnerability which is called animated cursor vulnerability in existing Windows platform this vulnerability was discovered in 2007 it's a way back people may think that it's almost 8 year back or 9 year back why we are going to talk about this vulnerability now

because still there are Legacy systems across the world which are available and those are hosting those Legacy operating system which were vulnerable to this vulnerability and if anybody might not have passed his or her system against this one vulnerability this vulnerability is going to cause a trouble of that system and it will allow a remote code execution to happen now remote code execution means somebody remotely is able to run a code on my machine which is very dangerous that means I'll be able to run a code on somebody else's machine without his KN how and that code may be stealing of the information I may format the hard disk that that is what is called remote code 5 minutes, 1 second execution running any code on somebody else's machine without proper authorization and

authentication and that is the ultimate goal of an hacker that I should be able to run a remote code and that remote code execution is one of the part of this animated cursor vulnerability let's do a step by step execution of this particular vulnerability and try to understand where INRI cases of this and how we'll be able to avoid this by patching the systems properly now in order to demonstrate this we are going to create an isolated environment where we are going to experiment with three systems one that system which is my host operating system which is Windows 10 second operating system is Linux and third operating system is Windows XP now this Linux system is going to host a malicious web

page and this Windows XP system is going to access that malicious web page and this malicious web page is going to offer a cursor which when gets executed this cursor once gets executed is going to allow me to run a remote code on that particular machine Let's do step by step execution of this so for this what I have done I would require internet access so that I can open up a page where a proof of concept is available and that proof of concept says that this is an animation file animate DOI file which will trigger the vulnerability when the folder containing it is open in Windows Explorer now I'm going to copy this vulnerability this particular code and paste it into a text file and this text file I have created in Linux so I'm just going to

open it I say Nano any. text I already pasted into this any. text now you can see whatever was available on the internet the same thing is available here on my machine because I just copy and paste it into a text file and I can check what kind of file it is by file command so I say file any do text so it say it's a asky text file now if I want to load this file on a remote machine first

of all I'm going to host this file in a web server and that web server we are going to use is called Apache web server now this particular text file cannot be loaded as an animated cursor because as soon as window operating system sees this it says it's a simple text file it's not an animated cursor file so first thing which we are going

to do we are going to filter out this middle portion from the file which starts with this 52 49 46 46 which is r i FF so this is a start of header for animated text file so we are going to copy this whole stuff as a stream and paste it in a binary file so that it becomes a animated cursor file so in order to do that we are going to play with this file through a shell so let me open I'll say cat I'm using a cat command to open any. text file so it shows me the content now next I want to filter out this content taking space as a delimiter so I say cat any. txt and then I say cut minus D which is a d limiter and I say space as a delimiter and I need field number three to 22 so why I say field number 3 to 22 you can count so this particular address 0000 0 so this is the first field then

we have a blank space which is the second field and field three starts from this 52 so this is field three and then up to this 68 this is field number 23 so we are going to take from F3 to 23 and you see what it gives me it gives me the center part of a file now I have to get rid of these spaces also and apart from these spaces I'm going to get rid of sln at the end so I'm going to write this I say cut minus D F3 and then pipe this particular output to a stream editor and in the Stream editor I say substitute space with non space globally now as soon as I do this you see I have got a stream of hexadecimal characters but still there is sln which is available in this so I'll get rid of that also by using a

translation so I output this particular output into a translator I said TR and I said delimiter as sln so sln is a delimiter now you see I got a stream of characters so I'm going to copy this whole stream start from 52 I'll copy until this 43 right click and say copy I copied the stream now I am going to paste this whole string into a binary file so that it becomes a animated cursor file so in order to in order that to happen I'm going to say Echo and I put any character let's say m into a file called demo do Ani so it created a file called demo. so if I say file demo. it says a asky text file because still it does not have that riff header in place so now we are going to open this file as hexedit minus B

demo. now as you can see it has only two character one is M and followed by enter so I'm going to fill this whole file by zeros and these zeros will make a space for my buffer which I copied just now so good enough enough a space at this point of time so we'll paste that stuff which we have copied here so as you can see and rest of the zeros I'm going to delete so all other stuff is going to get deleted from this file now I have perfectly the same kind of file which was available on the internet as proof of concept with me now it starts from 52 49 46 46 which is RF header and it goes up to 43 43 43 43 which is equalent to c c c c as in the S text so I'll say contr x save this file demoi in this folder and now check it with file command I say file demo. Ani now let say

it is a little random data which is an animated cursor that means now my machine recognizes this particular file as an Ani file now I am going to tell this file to get uploaded on a web through a body cursor command and then this will be accessible to the outside world through a website URL now what is the next step to be done so we are going to create a page which is a crafted page and that page will have this content so I open up exp. HTML and I say here HTML body style cursor URL is demo. and I'm just typing animated cursor demo and then close the body and finally close the HTML part so this has created a exp. HTML 14 minutes, 1 second file in my current folder now I'm going to expose this with the help of a

browser so in order to know whether a server is running on my system or not a web server so I simply say a command netstat -tlnp minus a n More now here you can see it says the TCP protocol call port number 80 and this port is in listen state that means my Apache web server is running on this machine and it can offer web pages to the clients through a URL and this .html page is now available to the outside world now let's go to the Windows machine and try to access this particular web page so I'm going to open Internet Explorer and type the IP address of my Apache web server so I say 192.168.1.172 followed by exp. HTML now once I do this you see it simply says animated cursor demo but nothing happens on this machine as such that means my

window accepted this as an animated cursor and it might have tried to load it but this output is not available here as part of Internet Explorer so next thing what I am going to do I'm going to attach this particular file in order to understand what is happening inside the memory I'm going to open up OllyDbg which is a debugger and this debugger is going to debug my Internet Explorer program so so I say attach and search for I explore here I explore is a EX file which is actually Internet Explorer on my system so I attach this and I when I attach this function you see it is going to show me some things on the screen let's first of all understand what is an output of this so I'm going to run this program now the first pane Which you're seeing here

this pane is the memory area so the first part is The Logical addresses second part is the op code and third part is the assembly code and this program is getting debugged so I'm going to restart this program and I make this program run so it opens up uh Explorer now I say open the window HTTP colon 192.168.1.172 exp. HTML now as you can see what has happened you see this it says access violation when executing 42 42 42 42 that means my EIP which is my instruction pointer register as when I was explaining I was trying to tell you that this EIP is most important part because it contains the address of next instruction which is going to get executed now at this point of time what has happened this EIP is having a string 42 42 42 42 that means

this is a part of a buffer which I had sent to this particular program now EIP is pointing to this particular address 424242 which is not exactly as part of this program so that's why I'm getting an access violation so now because we got a buffer overflow and this has overwritten the EIP now we are going to play with this EIP and put some address here and this

particular address is going to catch my buffer and within a buffer I can implant a malicious code and by virtue of this malicious code I'll be able to run a remote code on the remote machine now how I'm going to do that let's first of all understand the structure of an ani file so I'm going to open this I'll say hexedit demo.

right you see this is a structure now what my point is that I want to jump from this 90 instruction and I want to go down here at 40 through 43 43 and after that I can embed a malicious code into this particular file because file Size Doesn't Matter here I can have a small file with a limited kind of Animation I can have a bigger file with more animation and that's why it is called animated cursor file now if I'm going to let's say overwrite a part of this file let's say 5249 I overwrite it with some instruction then my window is not going to recognize this as a animated cursor file so in order that this file gets recognized as a animated cursor file I will not be able to touch these four bytes next comes these two bytes from these two bytes I need to jump to this

location and if you count the number of bytes these bytes are much more than 127 which is a limit for a short jump so the short jump can be at the maximum 127 bytes so I can jump from one location of memory to another location of memory by having 127 bytes at has a maximum jump so I am going to do here I'll say EB that jump from this part up to 16 bytes so 16 bytes are going to take me to this 0 0 0 0 and luckily I'll be able to overwrite this part also so I'll say EB 77 which will take me to this particular address here that means I I have created two jumps one jump of 21 bytes from EB 90 that is eb16 to e77 so this is a small island so I created a small island and jump from one memory location to this

island and from this island I'll jump back to my buffer and within a buffer I'll have a malicious code I hope you now understand that what I trying to do here so now first of all let's safeguard this and make these bytes as no operations 90 90 90 90 so 90 90 90 is a no operation and here at 42 42 42 I need a address which is going to point to my buffer so this address we'll find out in the memory so first of all let's save this file and I'm going to go back to my Windows machine and in the Windows machine I'm going to restart this debugger so I say restart now I'll open up this file in Explorer so I give the address I say 192 do 16872 128. exp. HTML so now you see again it crashes and my memory area is 52 52 52 and this 52 5 42

42 42 sorry not 52 this 42 42 42 42 this is pointing to a memory location which is over written now I need to find out a register here which is going to point to my Rift buffer so that I can jump back to this buffer so if we go here to ESI buffer and say follow in Dum so I see in memory there are certain address which are written but if I click on this addresses and again right click and say follow this double word in dump you see I got a buffer available in memory at this particular address and now I'll be able to jump to this address through this EIP manipulation so now we need to do one thing here we first of all need to find address of ESI jump double word in the memory now where I'm going to find it so for that we need to learn one concept and that concept is apart from my

program let's say my program name is ABC apart from this program in memory there are many other dll file files which are sitting in memory like user 32 shell 32 Kel 32 etc etc so these are the file which are available in the memory and if these files are available to my program in memory so what may happen my program can access the memory location of user 32 of shell 32 or of Kernel 32 if is available if the A's violation is not permitted in that case now if we see ABC if we see ABC here so ABC is going to access user 32 and by virtue of which I'll be able to find the address of jump ESP instruction now if we go back to original program we saw that in the memory there is an address which is pointed by

25 minutes, 1 second ESI and once we found this address we are going to overwrite over EIP with that address so up to this we have seen in the next class we are going to explore further and find out this address within a memory space and this memory space would be of user32.dll once we we found that address we are going to embed our buffer with this new address and with this new address we'll be able to jump to that location and execute an arbitrary code on the remote machine so within this lecture I had explained you a animated cursor vulnerability this vulnerability is going to expose many of the Windows system Windows XP Windows 2000 and even Windows Vista and this vulnerability gets executed whenever a user visits a

26 minutes, 1 second malicious web page and that malicious web page is hosted on a server and This Server contains this animated proof of concept and we are going to explore it further that how we'll be able to run a remote code execution on this particular site so with a reference to this you can go back home and study more about CLI side attacks and buffer overflow so meet you in the next class thank you